Information Security Policy Consultation Report

Consulting Note on Discretion

To maintain discretion and observe industry best practices, this project refers to the evaluated institution as "Large Public Research University (LPRU)." The analyzed text originates from a publicly available, unclassified corporate governance document.

Project Overview

This project connects compliance theory and practical consulting. Applying methodologies from my GRC Mastery and ISO 27001 Lead Auditor training, I performed a consultative review of LPRU's public information security policy. My approach commenced with a detailed review of the published policy document, followed by structured evaluation against ISO/IEC 27001:2022 Clause 5.2 requirements. I assessed key areas, including responsibility assignment, objective measurability, and documentation methods. In a real engagement, I would supplement document review with targeted stakeholder interviews to clarify policy intent and operational realities. This process would ensure a rigorous evaluation and actionable recommendations.

Universities have the difficulty of balancing open academic access with strong protection of institutional assets. This project helped me strengthen my evaluative skills in a complex business environment. By evaluating the policy against ISO/IEC 27001:2022 Clause 5.2, I identified ownership ambiguity, unrealistic security objectives, and gaps in document lifecycle management. The final deliverable provides a phased remediation roadmap to align governance with operations while maintaining business continuity.

Executive Summary

To: LPRU Executive Board

From: Xavius Johnson, Lead Information Security Consultant

Subject: Consultative Review of the Information Security Policy

Purpose of this Engagement

This review assesses the current LPRU Information Security Policy. Serving as the lead information security consultant, I took primary responsibility for conducting the assessment,

directing the analysis, and formulating recommendations. The objective is to transform the policy from a passive statement into an active, enforceable governance tool aligned with ISO 27001.

Scope

This engagement conducts a consultative gap analysis of the high-level Information Security Policy, focusing on compliance with the governance principles in ISO/IEC 27001:2022 Clause 5.2.

Out of Scope

This review is limited to the core policy document and excludes operational policies, standards, technical procedures, and independent implementation evidence.

Key Themes Identified

Although the policy sets a foundational intent to protect university assets, analysis shows three systemic areas calling for refinement for successful operations:

1. Accountability & Ownership of Security Functions:

The current policy employs passive language that obscures individual ownership of key operational and planning functions. In a large, decentralized institution, unclear accountability increases risk, delays incident response, and creates an ambiguous security posture that cannot keep pace with advancing threats.

2. Operational Feasibility & Risk Realism:

The objective to "protect against all threats" is conceptually flawed, as it promises absolute security. This unachievable standard prevents executive leadership from adopting a practical, risk-based approach, complicates budgeting, hinders resource allocation, and leaves critical risks unaddressed.

3. Governance Lifecycle & Documentation Review:

The lack of a structured review schedule and reliance on subjective timelines, such as "regular basis," make the governance framework prone to obsolescence. Without proactive lifecycle management, security documentation can stagnate and fall out of sync with changing infrastructure and regulatory requirements.

The Advisory & Gap Analysis Matrix

Section / Current Text	Consultant Analysis	Recommended Path Forward
Review Cadence *"...shall be reviewed and updated on a regular basis to ensure..."*	The commitment to review the framework on a 'regular basis' establishes an undefined cadence. This lack of a structured, measurable timeline significantly increases the likelihood of policy stagnation and an obsolete security posture.	Update the text using active voice and designate the Chief Information Security Officer (CISO) as the process owner, with final sign-off from the Executive Committee.
Incident Management *"...LPRU will maintain a Cyber Security incident management process..."*	The policy must explicitly designate individual ownership over critical cybersecurity operations. Obscuring this responsibility across the generic institution introduces severe operational risk, potentially causing critical delays during active incident response scenarios.	Assign the maintenance and execution of the incident response plan to a specific role, such as the Director of Cyber Security or Head of IT.
Strategic Objectives *"...we the management..."*	The colloquial phrasing 'we the management' introduces critical governance ambiguity. Failing to define the exact executive body responsible for authorization creates severe accountability gaps in strategic security planning and oversight.	Replace colloquial pronouns with the explicit title of the governing executive body to ensure clear authorization.
Policy Purpose *"...to protect... Information Assets and Services from all threats..."*	Industry-standard cybersecurity frameworks utilize a risk-based, defense-in-depth approach rather than promising total threat elimination. Because technologies and threat landscapes continuously evolve, the policy's objective must shift to strategically mitigating applicable institutional risks while enabling core business operations.	Reframe the purpose statement around risk mitigation and risk tolerance rather than absolute threat elimination.
Document Metadata *(Missing Next Review Date)*	A rigorous document lifecycle is vital to maintaining an effective security policy. Without explicit review milestones and unambiguous ownership, governance commitments become functionally unenforceable and are frequently deferred or neglected.	Embed a standardized Document Control Table at the beginning of the policy detailing ownership, version history, and a hard deadline for the next review.
Framework Implementation *"...will develop an Information Security framework... and will*	The deployment of future-tense language ('will develop') implies that the core governance framework does not yet exist. A compliant policy must establish an active, operational framework that is explicitly	Change the tense to reflect an established framework and replace "regular basis" with a measurable, planned interval (e.g., "at least annually").

review these on a regular basis"	communicated to, and enforceable upon, all institutional stakeholders.	

Conclusion

By addressing these structural gaps, LPRU can transform its Information Security Policy into an active, enforceable governance tool. Aligning the policy with ISO/IEC 27001:2022 Clause 5.2 removes ambiguity, protects resources with realistic risk-based metrics, and creates clear executive accountability throughout decentralized systems.

Recommended Roadmap

Remediation should follow a planned schedule to minimize operational disruption and develop a comprehensive security policy aligned with ISO 27001, reducing organizational risk.

Phase 1: Accountability and Text Remediation (Immediate / 1–30 Days)

- Update the policy wording using the proposed rectified language outlined in the Advisory Matrix. Formally replace colloquial pronouns ("we") and passive wording with explicit organizational roles (e.g., CISO, Executive Board).

Phase 2: Formal Authorization and Governance Mapping (Short-Term / 30–60 Days)

- Route the corrected draft to the University Executive Board for formal review, approval, and official sign-off. Insert the completed Document Control Table into the policy metadata to permanently lock in an enforceable, annual review cadence.

Phase 3: Institutional Distribution and Awareness (Medium-Term / 60–90 Days)

- Publish the approved policy to all academic faculties, staff, students, and third-party vendors. Integrate the newly defined incident reporting pathways and ownership structures into mandatory employee security training.